

Week 2: Vulnerability Assessment Report

Name: Akash B. Nair

Tool: Nessus Essentials

Target: Metasploitable2 (192.168.56.101)

Scanner: Kali Linux

Objective

Perform a comprehensive vulnerability assessment on Metasploitable2 using Nessus Essentials, categorize findings by severity, verify them using CVSS/CVE information where available, and recommend mitigations.

Lab Environment

Scanner: Kali Linux

Tool: Nessus Essentials

Target: Metasploitable2

IP: 192.168.56.101

Scan: Basic Network Scan

Virtualization: Oracle VirtualBox

Methodology

- Installed and configured Nessus Essentials.
- Updated and compiled plugins.
- Created a Basic Network Scan.
- Executed the scan against the target.
- Reviewed and categorized vulnerabilities.

Scan Summary

The scan detected 70 vulnerabilities.

Critical: VNC Server 'password' Password, SSL v2/v3 Detection, Ubuntu 8.04 EOL, Bind Shell Backdoor.

High: Samba Badlock, rlogin Service Detection.

Medium: NFS Shares World Readable, Unencrypted Telnet Server.

Low: SSL Anonymous Cipher Suites Supported.

Critical - VNC Server 'password' Password

CVSS: 10.0

Description: Default VNC password allows unauthorized access.

Mitigation: Change default credentials and restrict access.

Critical - SSL Version 2 and 3 Protocol Detection

CVSS: 9.8

Risk: Downgrade and MITM attacks.

Mitigation: Disable SSLv2/v3 and use TLS 1.2+.

Critical - Ubuntu Linux End of Life

CVSS: 10.0

Risk: No security updates available.

Mitigation: Upgrade to a supported version.

Critical - Bind Shell Backdoor Detection

CVSS: 9.8

Risk: Remote command execution.

Mitigation: Remove unauthorized services and monitor ports.

High - Samba Badlock Vulnerability

CVSS: 7.5

Mitigation: Update Samba and restrict SMB access.

High - rlogin Service Detection

CVSS: 7.5

Mitigation: Disable rlogin and use SSH.

Medium - NFS Shares World Readable

Mitigation: Restrict NFS exports to trusted hosts.

Medium - Unencrypted Telnet Server

Mitigation: Replace Telnet with SSH.

Low - SSL Anonymous Cipher Suites Supported

Mitigation: Disable anonymous cipher suites.

Risk Assessment

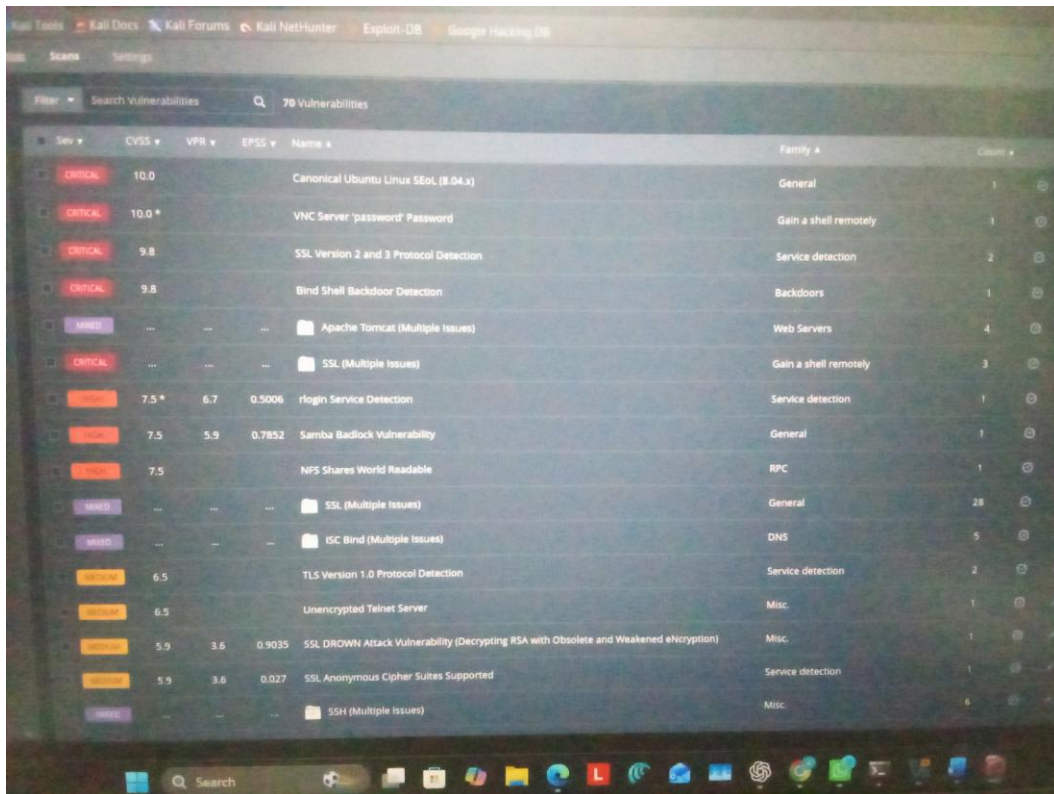
- Patch critical vulnerabilities immediately.
- Address high-severity findings promptly.

- Harden configurations for medium and low findings.
- Conduct regular vulnerability assessments.

Conclusion

The assessment identified 70 vulnerabilities, including critical issues such as default credentials, obsolete SSL protocols, unsupported operating systems, and backdoor services. The results highlight the importance of patching, secure configurations, and continuous vulnerability management.

Evidence: Nessus Scan Screenshots



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (B.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
MEDIUM	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1
MEDIUM	...	...	...	SSL (Multiple Issues)	General	28
MEDIUM	...	...	...	ISC Bind (Multiple Issues)	DNS	5
HIGH	6.5			TLS Version 1.0 Protocol Detection	Service detection	2
HIGH	6.5			Unencrypted Telnet Server	Misc.	1
HIGH	5.9	3.6	0.9035	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eEncryption)	Misc.	1
HIGH	5.9	3.6	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1
MEDIUM	...	...	...	SSH (Multiple Issues)	Misc.	6

Figure 1: Nessus vulnerability summary showing critical, high, medium, and low findings.

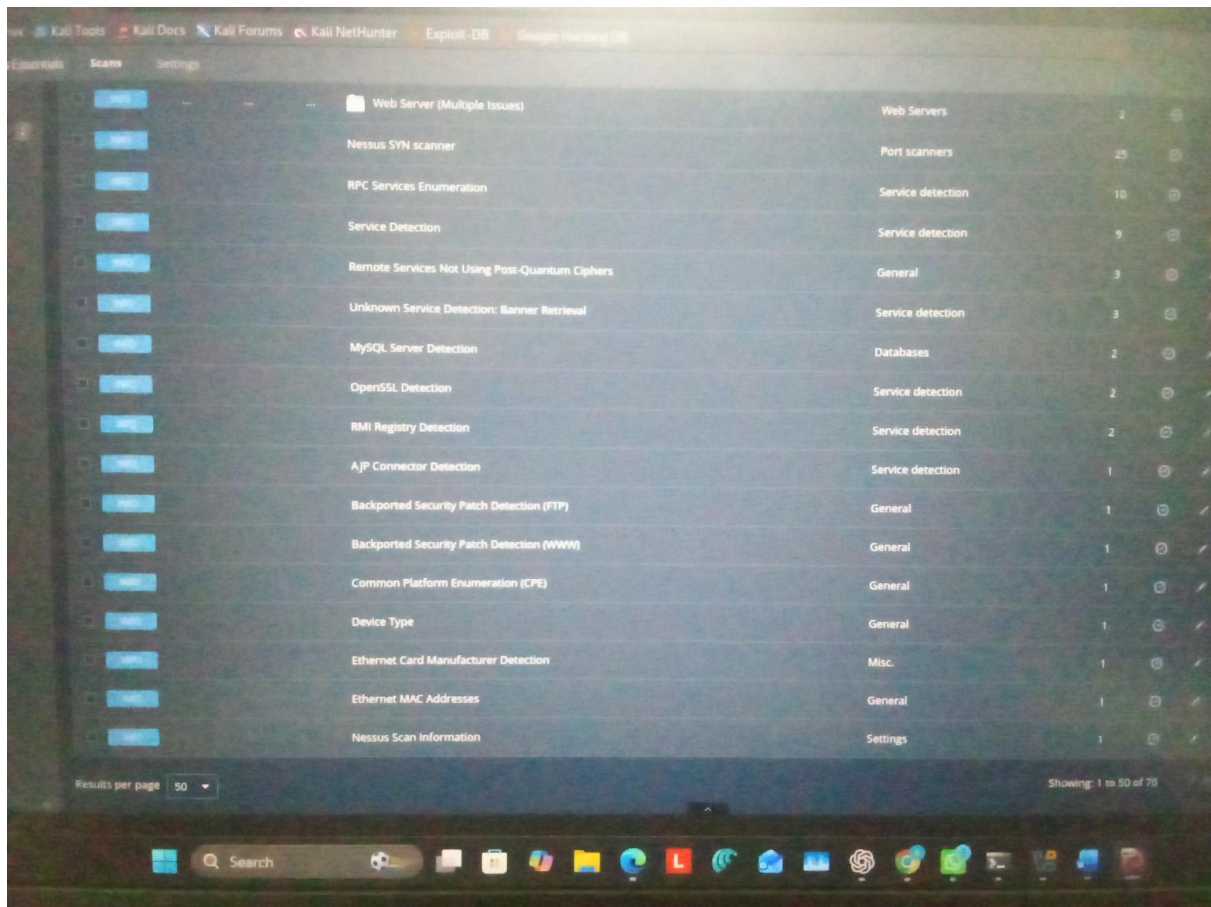


Figure 3: Informational findings and service detection results from Nessus.